

Day18 信息打点-APP资产&知识产权&应用监控 &静态提取&动态抓包&动态调试

业务资产

- 查询平台
 - 爱企查
 - 小蓝本
- 业务类型
 - 1. WEB应用
 - 2. APP应用
 - 3. PC端应用
 - 4. 小程序应用
 - 5. 微信公众号
 - 6. 其他产品等

架构

- 分类
 - 1. 程序语言
 - 2. 框架源码
 - 3. 搭建平台
 - 4. 数据库类
 - 5. 操作系统

技术

- 指纹识别
 - 平台
 - 指纹识别 Wappalyzer <https://github.com/AliasIO/wappalyzer>
 - 指纹识别 TideFinger潮汐 <http://finger.tidesec.net/>
 - 指纹识别 云悉指纹 <https://www.yunsee.cn/>
 - 内网: cmsseek cmsmap

域名

- 单域名
 - 1. 备案信息
 - 2. 企业产权
 - 3. 注册域名
 - 4. 反查解析
- 子域名
 - 1. DNS数据
 - 2. 证书查询
 - 3. 网络空间
 - 4. 威胁情报
 - 5. 枚举解析
- 平台
 - DNS数据 [dnstumpster https://dnstumpster.com/](https://dnstumpster.com/)
 - 证书查询 [CertificateSearch https://crt.sh/](https://crt.sh/)
 - 网络空间 [FOFA https://fofa.info/](https://fofa.info/)
 - 网络空间 全球鹰 <http://hunter.qianxin.com/>
 - 网络空间 360 <https://quake.360.cn/quake/#/index>
 - 威胁情报 微步在线 情报社区 <https://x.threatbook.cn/>
 - 枚举解析 DNSGrep子域名查询 <https://www.dnsgrep.cn/subdomain>
 - 枚举解析 工具强大的子域名收集器 <https://github.com/shmilyity/OneForAll>

开源

- 利用指纹识别找到CMS
- 官方去下载

源码获取

- 闭源
 - 平台
 - github
 - gitee
 - oschina
 - QQ号
 - 邮箱地址
- 泄露方案
 - git
 - svn
 - ds_store
 - 压缩备份
 - composer

1 Web应用

JS前端架构



人工

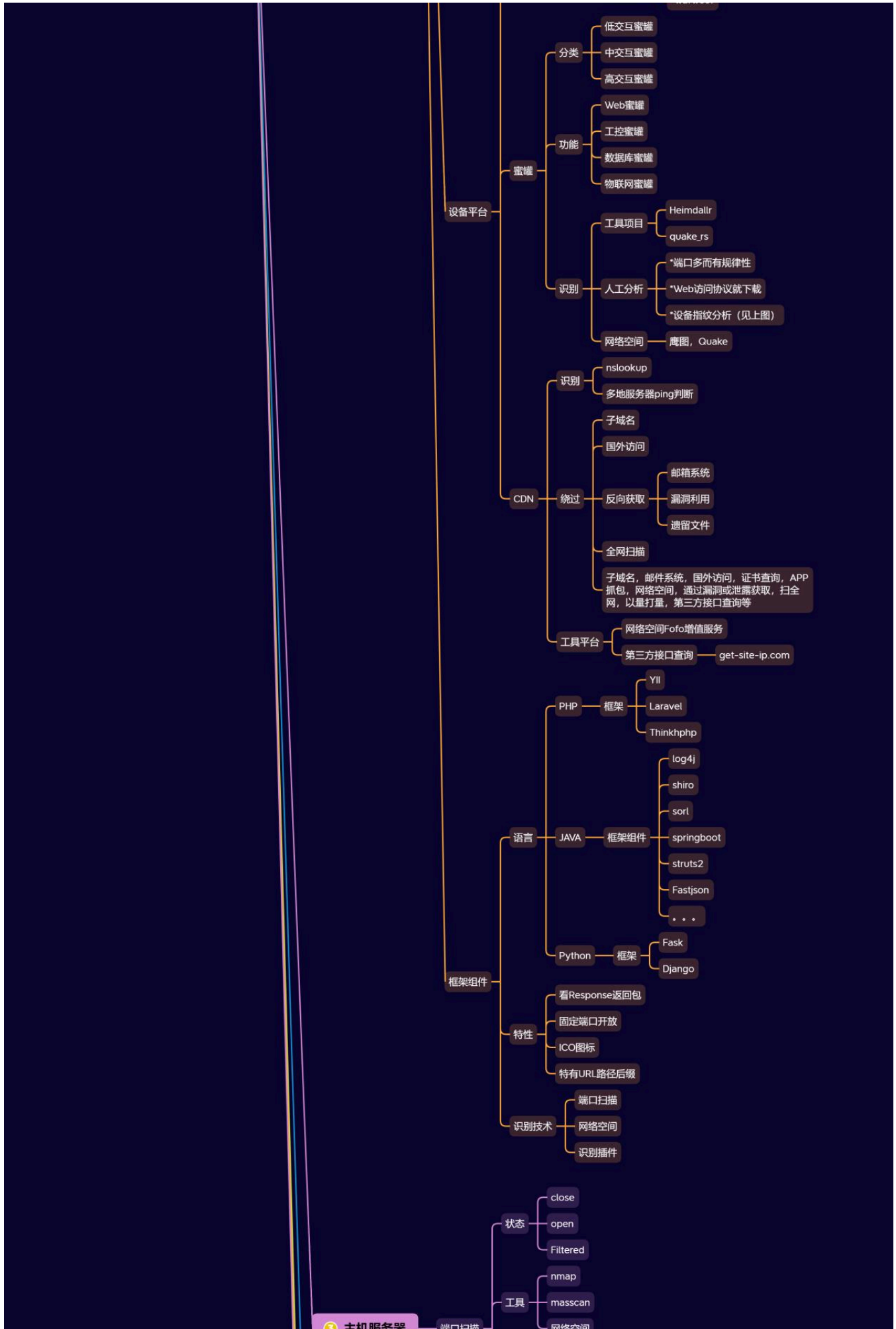


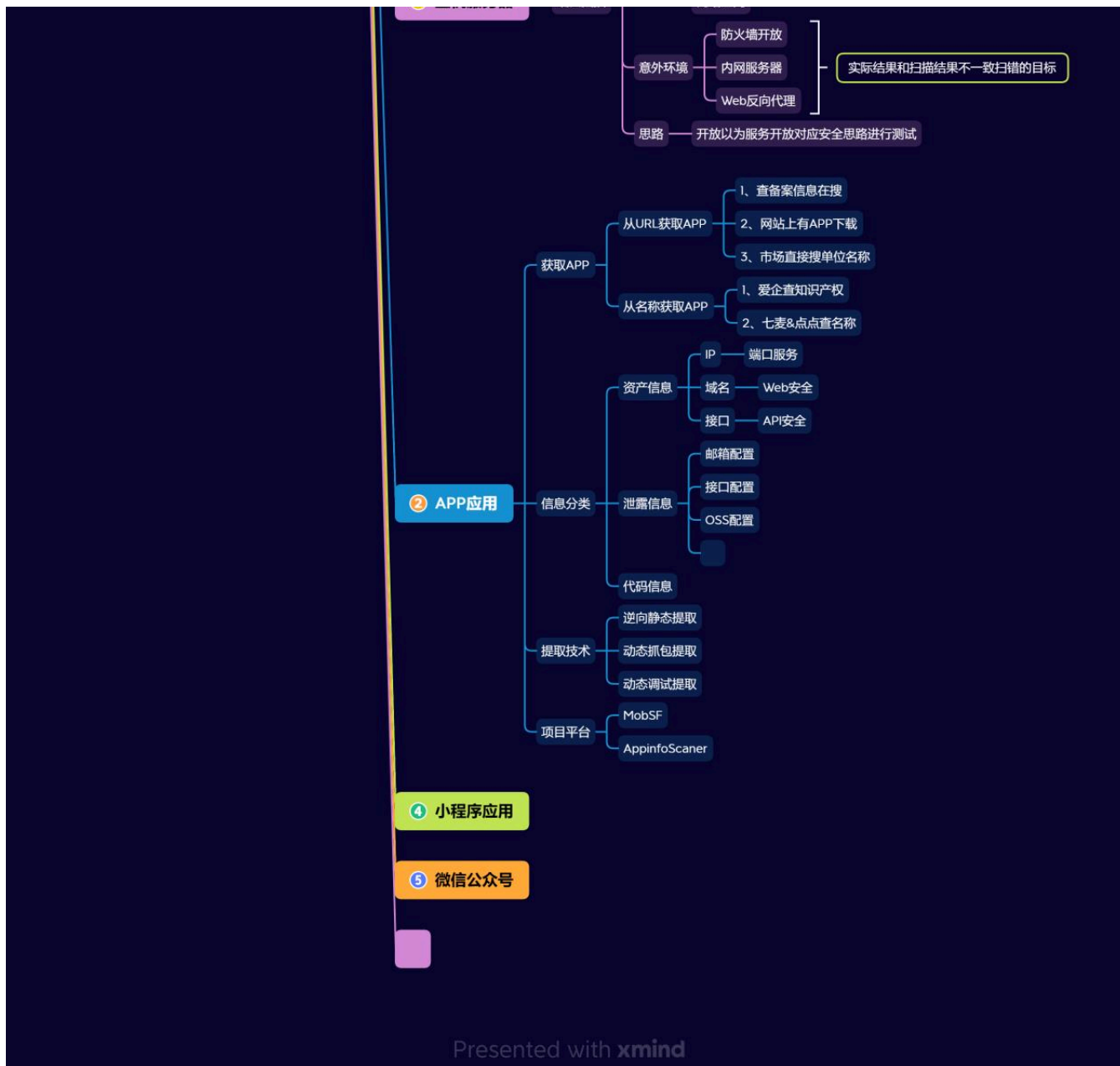
测试方法



WAF







1.知识点

- 1、业务资产-应用类型分类
- 2、Web单域名获取-接口查询
- 3、Web子域名获取-解析枚举
- 4、Web架构资产-平台指纹识别

- 1、开源-CMS指纹识别源码获取方式
- 2、闭源-习惯&配置&特性等获取方式
- 3、闭源-托管资产平台资源搜索监控

- 1、JS前端架构-识别&分析
- 2、JS前端架构-开发框架分析

- 3、JS前端架构-打包器分析
- 4、JS前端架构-提取&FUZZ

解决:

- 1、如何从表现中的JS提取价值信息
- 2、如何从地址中FUZZ提取未知的JS文件
- 3、如何从JS开放框架WebPack进行测试

- 1、端口扫描-应用&协议
- 2、WAF识别-分类&识别
- 3、蜜罐识别-分类&识别

解决:

- 1、Web服务器&应用服务器差异性
- 2、WAF防火墙&安全防护&识别技术
- 3、蜜罐平台&安全防护&识别技术

- 1、CDN 服务-解释差异识别
- 2、CDN 绕过-配置差异导致
- 3、CDN 绕过-主动连接获取
- 4、CDN 绕过-全网扫描获取

解决:

- 1、CDN 服务对安全影响
- 2、CDN 服务绕过识别手法

- 1、CMS指纹识别-不出网程序识别

- 2、开发框架识别-PHP&Python&Java
- 3、开发组件识别-Java常见安全漏洞组件

解决:

- 1、CMS识别到后期漏洞利用和代码审计
- 2、开发框架识别到后期漏洞利用和代码审计
- 3、开发组件识别到后期漏洞利用和代码审计

-
- 1、Web&备案信息&单位名称中发现APP
 - 2、APP资产静态提取&动态抓包&动态调试

解决:

- 1、如何获取到目标APP信息
- 2、如何从APP信息中提取资产

2.详细点



- 1 CMS
- 2 Discuz、WordPress、Ecshop、蝉知等



- 1 前端技术
- 2 HTML5、jquery、bootstrap、Vue等



- 1 开发语言
- 2 PHP、JAVA、Ruby、Python、C#，JS等



- 1 web服务器
- 2 Apache、Nginx、IIS、lighttpd，Apache等



- 1 应用服务器:
- 2 Tomcat、Jboss、Weblogic、Websphere等



- 1 数据库类型:
- 2 Mysql、SqlServer、Oracle、Redis、MongoDB等



- 1 操作系统信息
- 2 Linux、windows等



- 1 应用服务信息:
- 2 FTP、SSH、RDP、SMB、SMTP、LDAP、Rsync等



- 1 CDN信息
- 2 帝联、Cloudflare、网宿、七牛云、阿里云等



- 1 WAF信息
- 2 创宇盾、宝塔、ModSecurity、玄武盾、OpenRASP等。



- 1 蜜罐信息:
- 2 HFish、TeaPot、T-Pot、Glastopf等



- 1 其他组件信息
- 2 fastjson、shiro、log4j、OA办公等

3.演示案例

3.1 APP资产-Web&备案信息&单位名称发现



- 1 案例1: 名称获取APP信息 (爱企查/小蓝本/七麦/点点)
- 2 1、爱企查知识产权
- 3 2、七麦&点点查名称
- 4 <https://www.xiaolanben.com/>
- 5 <https://aiqicha.baidu.com/>
- 6 <https://www.qimai.cn/>
- 7 <https://app.diandian.com/>



- 1 案例2: URL网站备案查APP
- 2 1、查备案信息在搜
- 3 2、网站上有APP下载
- 4 3、市场直接搜单位名称



- 1 通过获取App配置、数据包，去获取url、api、osskey、js等敏感信息。
- 2 1、资产信息-IP 域名 网站 -转到对应web测试 接口测试 服务测试
- 3 2、泄露信息-配置key 资源文件 - key (osskey利用，邮件配置等)
- 4 3、代码信息-java代码安全问题- 逆向相关
- 5 APP中收集资产
- 6 1、抓包-动态表现
- 7 2、提取-静态表现&动态调试
- 8 3、搜索-静态表现



- 1 1、抓包抓表现出来的数据
- 2 优点：没有误报
- 3 缺点：无法做到完整
- 4 2、反编译从源码中提取数据
- 5 优点：数据较为完整
- 6 缺点：有很多无用的资产
- 7 3、动态调试从表现中提取数据
- 8 优点：没有误报，解决不能抓包不能代理等情况
- 9 优点：搞逆向的人能看到实时的app调用链等
- 10 缺点：无法做到完整

3.2 APP资产-静态提取&动态抓包&动态调试



- 1 案例：某APP打开无数据包，登录有数据包（反编译后未找到目标资产，抓包住到了）
- 2 原因：那个登录界面是APP打包的资源，并没有对外发送数据



- 1 案例3：APP提取信息-静态分析
- 2 1、MobSF
- 3 2、AppInfoScanner
- 4 3、两个在线平台
- 5 <https://mogua.co/>
- 6 <https://www.zhihuaspace.cn:8888/>
- 7 <https://github.com/kelvinBen/AppInfoScanner>
- 8 <https://github.com/MobSF/Mobile-Security-Framework-MobSF>
- 9 windows - MobSF安装参考：
- 10 <https://www.cnblogs.com/B-hai/p/15696948.html>
- 11 <https://blog.csdn.net/ljh824144294/article/details/119181803>



- 1 案例3：APP提取信息-动态抓包
- 2 -前期部分抓包技术



- 1 案例3: APP提取信息-动态调试
- 2 -MobSF+模拟器